FINGERPRINT // 62F8509104228DF9

// CONFIDENTIAL STRATEGY //

OMNIPOTENCE ENGAGEMENT ARCHITECTURE

Strategic Nexus

Strategic Security Scoping v33.0 Omni-Review

ENTITY

Nexus Retail

NEXUS SCORE

50%

50

NEXUS INDEX

1.1 Engagement Coverage Index

This score reflects the breadth of technical validation across core governance pillars.

PILLAR	STATUS	PRIORITY
GOV	VALIDATED	Strategic
RES	GAP	Strategic
INT	VALIDATED	Strategic
PRI	GAP	Strategic
SOV	VALIDATED	Strategic
ID	GAP	Strategic

Business Profile & Objectives

PART I.A: BUSINESS CONTEXT

ENGAGEMENT PARAMETER	CLIENT SPECIFICATION
Engagement Description	**Strategic architectural review of the core platform.**
Primary Deliverable	**Final architecture blueprint and roadmap.**

1.5 Regulatory Alignment: PCI-DSS v4.0 Compliance Testing

Narrative: Explicit scoping to satisfy Payment Card Industry Data Security Standard (PCI-DSS v4.0) Requirements 11.4 and 11.4.5.

REGULATORY BODY — **Payment Card Industry Data Security Standard (PCI-DSS v4.0) (Global)**

ARTICLE/REF	TITLE	REQUIREMENT	SCOPING GUIDANCE
Requirement 11.4	Penetration Testing	Perform external and internal penetration testing.	Must cover the entire Cardholder Data Environment (CDE) and critical systems annually.
Requirement 11.4.5	Segmentation Testing	Validate that segmentation controls are operational.	Requires dedicated segmentation validation at least every six months for service providers.

Mandatory Evidence Artifacts:

- Penetration Testing Methodology
- Detailed Finding Log
- Segmentation Validation Proof
- Clean Retest Report

IMPLEMENTATION GUIDANCE — **MITRE**

T1190 - Exploit Public-Facing Application

Adversaries may attempt to take advantage of a weakness in an Internet-facing computer or program using software, data, or commands in order to cause unintended or unanticipated behavior.

T1078 - Valid Accounts

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.

T1566 - Phishing

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering.

T1059 - Command and Scripting Interpreter

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries.

A01:2021-Broken Access Control

Testing must validate that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification, or destruction of all data.

A02:2021-Cryptographic Failures

Testing must verify the protection of sensitive data in transit and at rest. This includes passwords, credit card numbers, health records, personal information, and business secrets.

A03:2021-Injection

Testing must validate that user-supplied data is not interpreted as commands or queries (e.g., SQL, NoSQL, OS command, ORM, LDAP, and EL expression or OGNL injection).

A04:2021-Insecure Design

Testing must evaluate the architectural design for missing or ineffective control design. Insecure design cannot be fixed by a perfect implementation.

IMPLEMENTATION GUIDANCE

CIS

Control 1: Inventory and Control of Enterprise Assets

Actively manage (inventory, track, and correct) all enterprise assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments.

Control 4: Secure Configuration of Enterprise Assets and Software

Establish and maintain the secure configuration of enterprise assets and software.

Control 12: Network Infrastructure Management

Establish, implement, and actively manage network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

2.1 Digital Chain of Evidence

Artifacts produced during this engagement follow a cryptographically-verifiable lifecycle.

LIFECYCLE PHASE	VALIDATION METHOD
Acquisition	SHA-256 Verified Capture
Processing	Air-Gapped Analysis Environment
Destruction	NIST 800-88 Compliant Wipe

2.2 Data Sovereignty & Residency

To adhere to regulatory data protection requirements, the following residency rules apply to all engagement artifacts.

FRAMEWORK	RESIDENCY MANDATE
PCI	Cardholder data MUST NOT be stored within assessment logs. All evidence must be heavily sanitized prior to storage.

2.3 Regulator Audit & Access Rights

The following audit rights and access privileges are contractually granted to the respective regulatory bodies.

REGULATOR	ACCESS RIGHTS
PCI	PCI Qualified Security Assessors (QSAs) have full rights to review testing methodologies and raw vulnerability data during the RoC assessment.

Target Scope & Access Readiness

Core Target Register

The following assets are explicitly in-scope for this engagement.

ID	TARGET / GROUP	TYPE	ENVIRONMENT	OWNER
TGT-001	api.nexus-bank.com	API Gateway	Production	Platform Team
TGT-002	10.50.0.0/16	Internal Network Range	Corporate	IT Infrastructure
TGT-003	iOS Mobile Application	Mobile Binary	Staging	Mobile Dev

Access & Test Data Readiness

Required access and data prerequisites.

PREREQUISITE	DESCRIPTION / STATUS
VPN Access	Client to provide OpenVPN profiles for two consultants.
API Credentials	Two sets of JWT tokens (1 Admin, 1 Standard User).
Source Code	Read-only access to the Mobile App repository.

Technical Scope of Work

PT-NET-EXT

External Network Penetration Test

A structured assessment of internet-facing infrastructure including firewalls, VPNs, mail gateways, and publicly reachable hosts. Testers simulate real-world attackers attempting to gain unauthorised access from outside the perimeter. Findings are rated by exploitability and business impact.

2 Days | €3,500 Budgetary ALLOC

PT-NET-INT

Internal Network Penetration Test

Simulates an attacker with initial foothold inside the corporate LAN — whether an insider threat, a compromised workstation, or post-phishing access. The assessment covers lateral movement, privilege escalation, network segmentation effectiveness, and sensitive data exposure.

3 Days | €5,000 Budgetary ALLOC

PT-APP-WEB

Web Application Penetration Test

Manual-led security testing of web applications aligned to the OWASP Top 10 and WSTG, covering injection flaws, broken authentication, sensitive data exposure, XML external entities, broken access control, security misconfigurations, XSS, insecure deserialisation, and business logic vulnerabilities.

3 Days | €4,000 Budgetary ALLOC

PT-APP-API

REST/GraphQL API Security Testing

Targeted assessment of REST, SOAP, and GraphQL APIs using the OWASP API Security Top 10 framework. Covers broken object-level authorisation, excessive data exposure, lack of rate limiting, broken function-level authorisation, mass assignment, security misconfiguration, and injection flaws.

2 Days | €3,500 Budgetary ALLOC

Omni Control Matrix

3.1 Omni Control Mapping

The following granular controls are in scope for the selected execution modules.

CONTROL ID	DOMAIN	DESCRIPTION
AC_01	None	None
IA_02	None	None
SI_04	None	None

RACI Governance

PART III.C: RACI MATRIX

3.2 RACI Governance Matrix

Responsibility Assignment Matrix for engagement activities.

ACTIVITY	PROVIDER	CLIENT SEC LEAD	CLIENT IT	CLIENT EXEC
Project Kick-off	**R**	**A**	**C**	**I**
Access Provisioning	**C**	**I**	**R**	**A**
Technical Testing	**R**	**A**	**I**	**C**
Report Delivery	**R**	**A**	**C**	**I**
Remediation Sign-off	**C**	**I**	**R**	**A**

Quality Assurance & Peer Review

PART IV: QUALITY ASSURANCE

Formal Quality Assurance Gate

Based on the selected regulatory frameworks and execution modules, the following QA routing is algorithmically enforced.

REQUIRED QA LEVEL: Compliance & Privacy-Aware Reviewer

Mandatory compliance review gate. Evidence must be sanitized and mapping confirmed by a privacy-aware technical reviewer.

Verification & Sign off

NEXUS SEAL

Executive Sponsor Approval

Lead Strategic Provider

FINGERPRINT // 62F8509104228DF9FF1D920C3D316A128C2F8D22C2940B2A000DA9C2F2FE146E

Engagement Sign-Off

By signing below, the client agrees that this unified scoping document satisfies the engagement coverage requirements for DORA, FRB, HKMA, and PRA compliance regimes.

Executive Sponsor: _____

Date: _____